PREMIER MINISTRE
Liberté
Égalité
Fraternité

Annexe 1 CCTP : Obligations du titulaire et exigences de sécurité Lot 1

1. Obligations de sécurité du Titulaire applicables aux équipes produit et au cycle de vie des services numériques

Afin d'assurer une mise en œuvre progressive et maîtrisée, les mesures de sécurité sont réparties par phase du cycle de vie produit. La conformité à une phase suppose la conformité à toutes les exigences des phases antérieures.

Les informations et consignes de sécurité sont diffusées au sein des équipes produit par le Titulaire et font l'objet d'un atelier sécurité obligatoire à l'arrivée de chaque nouveau membre.

➢ Phase de démarrage / investigation

Dès la prise de poste :

- Appliquer sans délai les mises à jour du poste de travail (OS, applications). *(SECU_MCS_001, SECU_MCS_002)*
- Utiliser un gestionnaire de mots de passe pour la gestion des secrets. Éviter tout stockage en clair ; si nécessaire, fractionner les informations sur plusieurs canaux. *(SECU_INTERCO_003)*
- Choisir des mots de passe longs (≥ 20 caractères), complexes et uniques par service, avec activation systématique du 2FA lorsque disponible. *(SECU_INTERCO_003)*
- Ne partager les accès qu'avec les personnes ayant un besoin justifié. *(SECU_SRE_005)*
- Créer un compte individuel par utilisateur ; éviter tout compte partagé. *(SECU_SRE_005, SECU_ACCES_003)*
- Chiffrer les supports de stockage, notamment les disques durs des postes de travail. *(SECU_SPT_001, SECU_SPT_004, SECU_NOMADE_002)*
- Mettre en place un mécanisme automatique de verrouillage de la session après une certain période d'inactivité *(10 minutes) (SECU_SPT_002).*

➢ Phase de construction

Avant l'ouverture du service à des utilisateurs externes :

- Enregistrer le produit sur *MonServiceSécurisé* [1].
- Séparer les environnements (local, staging, production) et utiliser des variables d'environnement non versionnées. *(SECU_SRE_001, SECU_SRE_002, SECU_DEV_006)*
- Organiser un atelier d'analyse de risque stratégique (2h) afin d'identifier les premières mesures à déployer. *(SECU_HOM_001)*
- Contacter la cellule Cyber / RSSI pour validation des mesures et des pratiques recommandées.

- Activer l'authentification 2FA sur les dépôts de code et imposer son usage à tous les membres disposant de droits d'administration. *(SECU_INTERCO_003)*
- Mettre en place un double contrôle obligatoire des modifications du code (validation PR/MR) *par deux développeurs différents (SECU_DEV_005).*
- Signer l'ensemble des commits fait sur le code et contrôler ces signatures avant tout déploiement en production *(SECU_DEV_005).*
- Les déploiements en production doivent se faire manuellement ou automatiquement via un runner dédié et hébergé directement au sein de la plateforme de production. Le runner doit procédure à un contrôle de signature des commits lors du build afin de contrôler la légitimité de ce qui est mis en production *(SECU_DEV_005).*
- Développer dans un environnement conteneurisé, isolé du poste local. *(SECU_DEV_004, SECU_DEV_006)*
- Vérifier que l'hébergement est certifié ISO 27001 et utiliser les technologies conformes au [cadre de cohérence technique] [2]. Dans le cas d'un produit traitant des données d'une sensibilité particulière, assurez vous que l'hébergeur est qualifié SecNumCloud par l'ANSSI.
- Intégrer le *Design Système de l'État* (DSFR) [3].

➢ **Phase d'ouverture du service**

Après mise en ligne :

- Mettre en place une comitologie de sécurité (idéalement, tous les 4 mois) permettant la revue du plan d'action et la révision de l'analyse de risque *(SECU_HOM_001, SECU_HOM_003)*
- Rédiger un Dossier d'Architecture Technique (DAT) *(SECU_HOM_003, SECU_ACCES_002)*
- Sécuriser le site via SSL et paramétrer les en-têtes HTTP selon les bonnes pratiques (ex. Helmet.js, CSP adaptée).
- Mettre en place un contrôle automatique de fuite de secrets (ex : Talisman, GitGuardian).
- Suivre les erreurs applicatives (ex : Sentry) et auditer automatiquement le code et les dépendances (ex : CodeQL, Dependabot).
- Restreindre les accès aux environnements sensibles (production accessible à 1–2 personnes maximum). *(SECU_NOMADE_001, SECU_INTERCO_003, SECU_ACCES_001 à 003)*
- Mettre en place une veille CVE active et formalise les modalités d'application des correctifs selon la criticité CVSS. *(SECU_MCS_005 à SECU_MCS_008).*

2. Obligations du Titulaire dans le processus d'homologation des SI

Tout système d'information traitant des informations ou supports à protéger doit faire l'objet d'une homologation, consistant en la déclaration par une autorité dite d'homologation, que le système d'information considéré est apte à traiter des informations ou supports protégés conformément aux objectifs de sécurité visés, et qu'elle accepte les risques de sécurité résiduels induits.

La démarche d'homologation de sécurité suit le cycle de vie de la cible. C'est pourquoi tout au long du marché les éléments constitutifs du dossier de sécurité seront amenés à évoluer dans la limite de ce qui est prévu par la réglementation et les directives associées.

Le Titulaire établit pour chaque projet, un dossier d'homologation présentant les données et leurs traitements, les mesures générales et particulières de sécurité, les moyens de protection associés ainsi que les moyens et techniques concourant au fonctionnement du système d'information. Il recense les vulnérabilités résiduelles.

Exigence SECU_HOM_001

Le Titulaire assiste la DINUM dans l'élaboration de l'analyse de risques du système en vue d'identifier les risques auxquels l'application est confrontée en prenant en compte les potentiels impacts sur la vie privée des personnes dont les données font l'objet d'un traitement par le système d'information cible.

Exigence SECU_HOM_002

Le Titulaire réalise et met à jour les dossiers d'architecture technique de tous les systèmes d'information sur lesquels il intervient pour le compte de la DINUM. Chaque dossier d'architecture technique traite systématiquement des points suivants :

- Détail de l'architecture fonctionnelle : description des échanges métiers permettant au système de remplir sa mission ;
- Détail de l'architecture applicative : description des différentes briques applicatives du système, des échanges entre ces dernières et des fonctionnalités métiers associées ;
- Détail de l'architecture technique : description du socle technique sur lequel s'appuie le projet et les flux techniques associés (serveurs, stockage, réseau, sauvegarde) ;
- Détail de la résilience du système : capacité à continuer de rendre le service en cas de défaillance d'un composant technique ;
- Gestion de l'administration technique du système d'information ;
- Gestion des journaux d'évènements ;
- Description des mesures de sécurité permettant de garantir la confidentialité, l'intégrité et la disponibilité du système (durcissement des serveurs, identification/authentification, haute disponibilité, …).

Exigence SECU_HOM_003

Le Titulaire doit justifier dans le DAT les mécanismes de sécurité mis en place dans la solution en vue de répondre aux objectifs de sécurité identifiés dans l'analyse de risque. Ces objectifs peuvent être satisfaits par un logiciel personnalisé, un logiciel tiers ou l'environnement technique de la solution.

3. Obligations du Titulaire sur le maintien en condition de sécurité

Au titre du MCS, le Titulaire s'assure en permanence que le système reste apte à remplir ses missions conformément aux enjeux de sécurité identifiés, à compter de la conception et tout au long de la vie du système.

Exigence SECU_MCS_001
Le Titulaire veille à fournir les solutions de lutte contre les codes malveillants utilisés sur les systèmes des différents projets de la DINUM ainsi que les mises à jour de sécurité de l'ensemble des constituants des systèmes selon une fréquence et des procédures qui sont définies et acceptées par la DINUM.

Exigence SECU_MCS_002
Le Titulaire met en œuvre une veille de sécurité pour l'ensemble des produits (logiciels et matériels) de la DINUM, relevant du marché. Cette veille permet d'identifier les vulnérabilités relatives à ces produits et les correctifs de sécurité disponibles. La veille de sécurité au titre du MCS doit nécessaire être formalisée.

La veille est réalisée en utilisant plusieurs sources distinctes (éditeurs, sites institutionnels…)

Exigence SECU_MCS_003
En cas de mise en évidence d'une vulnérabilité affectant un système de la DINUM relevant du marché, le Titulaire collabore avec la DINUM pour déterminer l'origine de la vulnérabilité et les actions à engager pour sa résolution. Cette activité consiste à :

- Maintenir une veille sur les produits et collecter, agréger et synthétiser les informations traitant des évolutions de la menace et des vulnérabilités ;
- Collecter les alertes (bulletins) de sécurité observés en production ;
- Analyser la criticité d'une alerte ou d'un incident sur le système concerné ;
- Proposer des solutions de contournement en cas d'urgence (impossibilité de déployer rapidement un correctif) ;
- Recevoir/Récupérer un correctif ;
- Qualifier le correctif ;
- Déployer le correctif ;
- Entretenir la documentation système.

Exigence SECU_MCS_004
L'évaluation de la criticité doit utiliser la méthode CVSS (Common Vulnerability Scoring System).

Le système CVSS propose le calcul de trois notes comprises entre 0 (risque nul) et 10 (risque très élevé) :

- Note de base : impact maximum théorique ;
- Note temporelle : note de base pondérée par les correctifs existants ou à contrario les « exploits » ;

- Note environnementale : note temporelle affinée selon les déploiements des systèmes et leur contexte opérationnel. Cette note doit être soumise par le Titulaire au responsable sécurité de la DINUM (ou un représentant habilité par la DINUM) pour validation ou modification.

L'échelle de criticité de la version 3.1 du système CVSS doit être utilisée par le Titulaire lors de sa requalification de la note CVSS des vulnérabilités émises par les différentes sources du Titulaire (ex : CERT-FR).

Exigence SECU_MCS_005

Au titre de la requalification de la note CVSS et pour les vulnérabilités de criticité « Nul » ou « Faible » découvertes au titre du MCS, le Titulaire applique un correctif suite à sa découverte d'une faille :

- Dans les douze (12) mois pour les failles dont la note CVSS est égale à 0.
- Dans les six (6) mois pour les failles dont la note CVSS est comprise entre 0 et 3,9.
- Les délais sont comptés à partir de la validation par la DINUM de la note environnementale sauf décision contraire de l'autorité d'homologation du système.

Exigence SECU_MCS_006

Au titre de la requalification de la note CVSS et pour les vulnérabilités de criticité « Moyen » découvertes au titre du MCS, le Titulaire :

- Applique, si cela est techniquement possible, une mesure de contournement dans le mois ;
- Trouve et applique un correctif dans les trois (3) mois pour les failles dont la note CVSS est comprise entre 4 et 6,9.

Les délais sont comptés à partir de la validation par la DINUM de la note environnementale sauf décision contraire de l'autorité d'homologation du système.

Exigence SECU_MCS_007

Au titre de la requalification de la note CVSS et pour les vulnérabilités de criticité « Elevé » découvertes au titre du MCS, le Titulaire :

- Applique une mesure de contournement dans les sept (7) jours ;
- Trouve un correctif dans le mois pour les failles dont la note CVSS est comprise entre 7 et 8,9. En fonction des contraintes techniques, l'application du correctif peut être décalée en commun accord avec la DINUM et sur justification dûment motivée par le Titulaire.

Les délais sont comptés à partir de la validation par la DINUM de la note environnementale sauf décision contraire de l'autorité d'homologation du système.

Exigence SECU_MCS_008

Au titre de la requalification de la note CVSS et pour les vulnérabilités de criticité « Critique » découvertes au titre du MCS, le Titulaire :

- Applique, si cela est techniquement possible, une mesure de contournement dans les quarante-huit (48) heures ;
- Trouve et applique un correctif dans les sept (7) jours pour les failles dont la note CVSS est supérieure ou égale à 9. En fonction des contraintes techniques, l'application du correctif peut être décalée en commun accord avec la DINUM et sur justification dûment motivée par le Titulaire.

Les délais sont comptés à partir de la validation par la DINUM de la note environnementale sauf décision contraire de l'autorité d'homologation du système.

Exigence SECU_MCS_009
Le Titulaire garantit que le canal d'approvisionnement des correctifs de sécurité est de confiance. Le Titulaire garantit l'origine, assure un contrôle d'intégrité et en garde une trace pouvant être un élément de preuve en cas d'audit (par exemple : Procès-Verbal de livraison signé).

Exigence SECU_MCS_010
Le Titulaire identifie, au titre du MCS, les versions de logiciels obsolètes ou qui vont le devenir. Un logiciel qui n'est plus soutenu au niveau sécurité est déclaré obsolète. Cette déclaration est anticipée par le Titulaire en contactant les éditeurs pour obtenir leur calendrier de soutien (calendriers publiés pour les systèmes d'exploitation grand public par exemple).

4. Obligations du Titulaire sur la gestion des biens de la DINUM

Exigence SECU_GDB_001
Le Titulaire conserve et traite les données de la DINUM de manière séparée de ses propres données ou de données d'autres clients du Titulaire. Le Titulaire doit restreindre l'accès aux données de la DINUM suivant le principe de restriction au besoin d'en connaître. La DINUM doit donner ses performances dans le CCTP : droits d'accès, machines virtuelles séparées, disques séparés, machines physiques séparées.

Exigence SECU_GDB_002
Le Titulaire garantit que les modalités de stockage et d'échanges d'informations par mail permettent d'en assurer la confidentialité et l'intégrité.

Exigence SECU_GDB_003
Le Titulaire applique des règles de marquage sur les ressources techniques (matériels et logiciels informatiques, supports de stockage) et les supports papier pour faire savoir au personnel autorisé que ces éléments contiennent des informations sensibles ou classifiées.

5. Obligations du Titulaire sur la sécurité des réseaux et de l'exploitation

Exigence SECU_SRE_001
Le Titulaire est garant du bon cloisonnement (physique ou logique) des environnements utilisés dans le cadre de la prestation.

Exigence SECU_SRE_002
Le Titulaire chiffre tous les flux d'administration (système et fonctionnelle) par des procédés fiables garantissant la confidentialité et l'intégrité des données. Par ailleurs, les postes d'administration permettant l'accès aux environnements de la DINUM depuis le site du Titulaire doivent respecter les exigences suivantes (en suivant, à défaut d'une précision de la DINUM, les recommandations de l'ANSSI) :

- Les correctifs de sécurité et les mises à jour antivirus doivent se faire quotidiennement ;
- Les postes ne doivent pas avoir accès à un système d'information bureautique (messagerie, intranet…) ;

Les postes d'administration utilisés doivent être réservés exclusivement à cet usage. Tout accès au poste doit se faire de manière sécurisée que ce soit pour l'ouverture d'une session et l'accès

physique. Si un tel dispositif s'avère impossible à réaliser pour le Titulaire, la DINUM peut mettre à disposition, aux frais du Titulaire, des postes portables sécurisés pour les activités d'exploitation et de TMA.

Exigence SECU_SRE_003
L'installation, l'exploitation et l'administration des produits mis en œuvre dans le cadre des prestations sont conformes aux bonnes pratiques et aux règles de sécurité et d'exploitation établies par la DINUM. Toute exception fera l'objet d'un accord préalable écrit des équipes de la DINUM.
A ce titre, les mots de passe hérités des paramétrages d'usine des produits doivent systématiquement être modifiés lors de leur configuration pour les besoins de la DINUM.

Exigence SECU_SRE_004
Le Titulaire s'assure de la bonne installation et mise à jour d'un logiciel anti-virus sur tous les postes de travail et serveurs dont il est responsable dans le cadre de la prestation. La désactivation, même temporaire, d'un antivirus sur un serveur utilisé dans le cadre de la prestation devra avoir été préalablement validée par la DINUM.

Exigence SECU_SRE_005
Le Titulaire s'assure que son personnel devant accéder à des ressources informatiques ou réseau dans le cadre de la prestation (qu'elles soient hébergées chez le Titulaire ou chez la DINUM) dispose d'un compte individuel qui peut être :

- Soit un compte nominatif qui lui est personnel et qui ne sera utilisé uniquement par cette personne tout au cours de la vie du compte ;
- Soit un compte individualisé qui pourra être attribué à des personnes différentes au cours de la vie du compte tout en étant toujours attribué qu'à une seule personne à la fois.

Exigence SECU_SRE_006
Le Titulaire s'assure de la suppression de tous les comptes inutiles ou obsolètes. Il précise dans le PAS, la procédure de revue de ces comptes. Le cas échéant, il automatise le processus de blocage ou de suppression.

Exigence SECU_SRE_007
Le Titulaire doit fournir un inventaire justifié des comptes techniques (le compte propriétaire du fichier de la base de données, des données du serveur WEB, ...) nécessaires au fonctionnement du système.

Exigence SECU_SRE_008
Le Titulaire tient à jour la liste exhaustive des comptes d'accès au SI de la DINUM existants ainsi que des rôles et privilèges qui y sont associés. Il fournit cette liste à la DINUM sur demande. Le Titulaire effectue et formalise une revue trimestrielle des comptes d'accès aux serveurs et autres ressources du Titulaire utilisées dans le cadre de la prestation.

Exigence SECU_SRE_009
Le Titulaire met en œuvre les bonnes pratiques de définition des mots de passe de l'ANSSI sur l'ensemble des comptes d'accès utilisateurs aux postes de travail et applications sous la responsabilité du Titulaire.

Exigence SECU_SRE_010
Le Titulaire dispose des sources d'installation des logiciels utilisés dans le cadre de la prestation, lorsque ces logiciels ne sont pas mis à disposition par la DINUM.

Exigence SECU_SRE_011
Le Titulaire s'assure de la bonne validité des licences des logiciels qu'il met à disposition de son personnel ou de la DINUM dans le cadre de la prestation.

Exigence SECU_SRE_012
Le Titulaire est capable de fournir à la DINUM, sur demande, la liste de son personnel avec son nom, prénom et adresse mail, qui est intervenu à un instant donné sur le SI de la DINUM en astreinte.

Exigence SECU_SRE_013
Le Titulaire est responsable de l'analyse des traces systèmes, applicatives et réseaux en vue de détecter toute attaque ou tentative d'attaque et, le cas échéant, ajuster les configurations et paramètres de sécurité.

Toute attaque fait l'objet d'une fiche d'alerte à l'équipe SSI de la DINUM précisant a minima :

- Un résumé de l'attaque (en précisant son vecteur) et ses impacts potentiels ;
- L'adresse IP de l'attaquant ;
- Les impacts de l'attaque sur l'écosystème du système d'information cible (avec une note CVSS) ;
- Les actions à mettre en œuvre (Contournement ou correctif) ;
- La date de correction envisagée.

Les délais de correction sont assujettis à la note CVSS de la fiche d'alerte et doivent respecter les mêmes contraintes temporelles que celles indiquées dans le cadre du MCS.

6. Obligations du Titulaire sur la sécurité de ses postes de travail

Exigence SECU_SPT_001
En vue de prévenir le vol des données de la DINUM contenues dans les postes de travail nomade du Titulaire, celui-ci met systématiquement en place les mesures de protection suivantes :

- Utilisation d'un filtre de confidentialité ;
- Installation d'une solution de chiffrement surfacique nécessitant de préférence une authentification forte pour le déchiffrement.

Exigence SECU_SPT_002
Le Titulaire applique une durée de verrouillage automatique de session sur l'ensemble des postes qu'il met à disposition de ses personnels. Cette durée ne doit pas excéder l'heure.

Exigence SECU_SPT_003
Le Titulaire rend obligatoire l'utilisation de l'authentification forte (ex. carte à puce, token usb, …) pour l'accès au poste de travail utilisé pour l'administration technique des systèmes d'information de la DINUM.

Exigence SECU_SPT_004

Tous les postes de travail du Titulaire doivent disposer d'une solution de chiffrement robuste, en privilégiant les solutions qualifiées par l'ANSSI, afin de permettre le chiffrement des données sensibles de la DINUM que les personnels du Titulaire seraient amenés à stocker ou communiquer dans le cadre de leurs missions.

7. Obligations du Titulaire sur le traitement des incidents de sécurité

Exigence SECU_INC_001
Le Titulaire assure l'enregistrement et la traçabilité des incidents de sécurité et dispose d'un processus formalisé et opérationnel de gestion des incidents de sécurité sur son domaine SI.

Exigence SECU_INC_002
Le Titulaire contacte les interlocuteurs sécurité de la DINUM désignés pour signaler tout incident de sécurité SI susceptible d'affecter les données ou le SI de la DINUM :

- Si cet incident a lieu sur le SI de la DINUM, le Titulaire participera à la demande de la DINUM au traitement de l'incident ;
- Si cet incident a lieu sur le SI du Titulaire, le Titulaire autorisera la DINUM ou un tiers désigné à participer au traitement de l'incident (si la DINUM le souhaite).

En outre, des réunions périodiques d'analyse post-incident devront être planifiées avec la DINUM (traitement des causes profondes).

Exigence SECU_INC_003
Le Titulaire capitalise les procédures de résolution des problèmes techniques récurrents dans une base de connaissance dédiée qu'il fournit à la DINUM sur demande.

8. Obligations du Titulaire lors de l'accès aux locaux de la DINUM

Exigence SECU_AL_001
Tout personnel du Titulaire, que celui-ci soit l'un de ses salariés ou salarié d'un des sous-traitants du Titulaire, devant avoir accès aux locaux de la DINUM doit être nommément agréé selon la procédure en vigueur dans les locaux de la DINUM.

Le personnel du Titulaire est soumis pendant son séjour aux mêmes règles intérieures que les agents de la DINUM, notamment les politiques et procédures de sécurité des systèmes d'information, ainsi que les chartes administrateurs et utilisateurs. La DINUM peut retirer son agrément à tout moment sans avoir à énoncer ses motifs, le Titulaire devra proposer un remplaçant conformément aux exigences mentionnées supra.

Exigence SECU_AL_002
L'intervention dans les zones protégées de la DINUM est conditionnée à l'obtention d'une autorisation d'accès délivrée au personnel du Titulaire après enquête diligentée par le service de sécurité compétent pour l'autorité contractante au profit de laquelle le marché est exécuté. Le délai d'enquête est en moyenne de quinze (15) jours ouvrés et il est fait obligation au Titulaire de fournir à la DINUM :

- Les données d'état civil de son agent ;
- Une photocopie lisible et recto-verso d'un titre d'identité dont la nature varie selon la situation individuelle de l'agent visé :
  - une carte nationale d'identité (CNI) ou un passeport, en cours de validité, pour les ressortissants français et communautaires ;

- pour les systèmes d'information qui ne sont pas soumis à la mention de protection « Spécial France » : un titre de séjour en cours de validité avec une autorisation de travail valable ou carte de résident pour les étrangers extracommunautaires ;
- un justificatif de domicile de moins de trois (3) mois si l'adresse de l'agent diffère de celle portée sur le titre d'identité fourni.

9. Obligations du Titulaire intervenant au sein des locaux de la DINUM

Exigence SECU_TIERS_001
Au même titre que les agents de la DINUM, le Titulaire doit prendre connaissance et appliquer les référentiels internes de la DINUM et des SPM (politiques de sécurité numérique, directive d'utilisation des systèmes d'information, directive d'utilisation de la messagerie, …).

Exigence SECU_TIERS_002
Le Titulaire ne tente pas d'accéder à des informations ou des ressources informatiques ne faisant pas partie du périmètre de la prestation.

Exigence SECU_TIERS_003
Le Titulaire élabore et maintien un inventaire complet et à jour des matériels mis à sa disposition par la DINUM. Cette liste doit être transmise semestriellement au responsable désigné par la DINUM.

Exigence SECU_TIERS_004
Le Titulaire tient à jour la liste exhaustive des comptes d'accès aux systèmes d'information de la DINUM existants ainsi que des rôles et privilèges qui y sont associés. Il doit être en mesure de fournir cette liste à la DINUM sur demande. Le Titulaire doit également effectuer et formaliser une revue trimestrielle des comptes d'accès aux serveurs et autres ressources de la DINUM utilisées par le Titulaire dans le cadre de la prestation.

10. Obligations du Titulaire sur le nomadisme numérique

Dans le cadre de certaines prestations, quand cela est autorisé par la DINUM, il peut être envisagé que le Titulaire puisse se connecter à distance aux SI de la DINUM, notamment durant les périodes d'astreinte.

Exigence SECU_NOMADE_001
Dans le cas où la DINUM autorise formellement les accès distants vers ses systèmes d'information et ne fournit pas directement les moyens pour cette activité, le Titulaire met en place les solutions permettant de sécuriser ces accès distants et d'enregistrer les activités des intervenants pour les nécessités d'investigation, notamment en cas de crise cyber.

Exigence SECU_NOMADE_002
Le Titulaire met en œuvre un tunnel sécurisé avec chiffrement des communications (ex : VPN IPSec) pour la connexion à distance aux réseaux utilisés dans le cadre de la Prestation (que ce soient ceux du Titulaire, ceux de la DINUM ou les deux éventuellement). Le personnel du Titulaire devra explicitement lancer la connexion et s'authentifier pour obtenir l'accès à distance aux SI de la DINUM (connexion authentifiée non permanente) ou utiliser les services et moyens d'accès distants mis à disposition par la DINUM.

Exigence SECU_NOMADE_003
Le Titulaire restreint la connexion distante des personnels d'astreinte, aux horaires d'astreintes définis (ex. connexion distante non autorisée en horaires ouvrées), et aux ressources nécessaires en astreinte uniquement.

11. Obligations en cas d'interconnexion avec les SI du Titulaire

Dans le cadre de certaines prestations, une interconnexion est réalisée entre les SI de la DINUM et du Titulaire. Cette interconnexion doit être cadrée avec vigilance et respecter se conformer aux politiques, procédures et doctrines de la DINUM.

Exigence SECU_INTERCO_001
Le Titulaire ne doit pas tenter d'accéder à des informations ou des ressources informatiques ne faisant pas partie du périmètre de la prestation. Il doit remonter au plus tôt à la DINUM toute anomalie lui permettant d'accéder de manière privilégiée à des ressources qui ne relèvent pas de sa responsabilité.

Exigence SECU_INTERCO_002
En cas d'interconnexion des SI de la DINUM et du Titulaire, le Titulaire doit prendre les mesures de sécurité nécessaires afin de maintenir le niveau de sécurité global des SI.

L'interconnexion devra être réalisée via des infrastructures d'accès validées par la DINUM au travers d'une étude ciblée, dans le respect du cadre technique et des règles de sécurité de la DINUM.

Exigence SECU_INTERCO_003
Pour chaque interconnexion, les éléments suivants doivent être précisés dans la cartographie :

- Les flux et protocoles autorisés, ainsi que les ressources auxquelles le Titulaire est autorisé à accéder au travers de la zone « partenaires ». Ces éléments doivent être restreints au strict nécessaire ;
- Les modalités d'authentification requises : authentification par mot de passe, authentification forte par mot de passe unique ou par certificat ;
- Les modalités de chiffrement des échanges : le chiffrement des flux transitant sur Internet est requis ;
- Les exigences spécifiques de traçabilité des accès ;
- Les moyens de sécurité supplémentaires à mettre en œuvre : contrôle de conformité, outils de détection ou de prévention d'intrusion, contrôle de contenu, filtrage applicatif…

12. Obligations du Titulaire sur la sécurité des développements

Exigence SECU_DEV_001
Le Titulaire doit prioriser les logiciels du cadre de cohérence technique de la DINUM ou du catalogue de l'ANSSI.

Exigence SECU_DEV_002
Le Titulaire doit indiquer dans le PAS, la méthodologie adoptée pour assurer un développement sécurisé et d'audit des applications web (Par exemple, en s'appuyant sur les guides mis à disposition par l'OWASP ou la norme ISO 27034 relative à la sécurité applicative).

Exigence SECU_DEV_003

La sécurité de toutes les applications développées par le Titulaire doit être systématiquement validée par des audits automatiques de sécurité visant à identifier les vulnérabilités potentielles sur le code et ses dépendances.

Exigence SECU_DEV_004
Les développements effectués sous la responsabilité du Titulaire font partie du périmètre de l'activité de veille sécurité au titre du MCS.

A ce titre, le Titulaire doit mettre en place les processus et/ou outils permettant de garantir qu'aucun composant présentant des vulnérabilités connues pouvant mettre en péril la sécurité des systèmes d'information de la DINUM, ne soient accidentellement inclus dans la solution au cours des développements.

Exigence SECU_DEV_005
Le Titulaire doit utiliser un système de contrôle du code source qui authentifie les personnels contributeurs par une signature cryptographique et journalise toutes les modifications au produit de base du logiciel. Un contrôle des signatures doit être réalisé avant tout déploiement du code en production.

A ce titre, le Titulaire veille à mettre en place un double contrôle des modifications réalisées sur le code avec toute fusion sur la branche principale.

Exigence SECU_DEV_006
Le Titulaire doit garantir que les environnements de développement, de qualification, de préproduction seront séparés de manière logique et/ou physique de la plateforme de production.

Exigence SECU_DEV_007
Les données utilisées dans la constitution de jeux d'essais sur toutes les plateformes hors production ne doivent pas comporter de données réelles. Si des données réelles sont utilisées pour alimenter des plateformes différentes de celles de production, le Titulaire utilisera un outil permettant d'anonymiser les données. Le Titulaire précisera dans le PAS la méthode d'anonymisation choisie.

Exigence SECU_DEV_008
Lors de la conduite de tests de validation ou du déploiement, le Titulaire doit :

- Utiliser des données de tests anonymisées ;
- Ne pas provoquer de perturbations du système d'information de la DINUM lors des séances de tests ;
- Être en capacité de remettre en l'état initial les systèmes testés ;
- Ne pas introduire de régression vis-à-vis d'un état de sécurité atteint dans une version précédente.

13. Obligations du Titulaire sur la gestion des droits d'accès

Exigence SECU_ACCES_001
Le Titulaire doit mettre en place sur l'ensemble du parc de serveurs de la DINUM, des comptes d'accès nominatifs. Les droits des personnels d'exploitation doivent être limités au strict nécessaire pour la bonne réalisation de leurs missions.

Exigence SECU_ACCES_002
Le Titulaire doit veiller à limiter les droits des accès d'une application aux seuls fichiers dont elle est légitime d'accéder. Le Titulaire décrit dans le DAT du système d'information les règles de durcissements mises en œuvre pour s'assurer du respect de cette exigence.

Exigence SECU_ACCES_003
Le Titulaire doit garantir que l'accès d'une application à une base de données se fait avec un compte spécifique bénéficiant des privilèges nécessaires et strictement suffisants.

14. Obligations du Titulaire en matière de continuité d'activité

Exigence SECU_PCA_001
Pour chaque système d'information dont il a la charge dans le cadre du marché, le Titulaire assiste la DINUM dans la réalisation du bilan d'impact sur l'activité des systèmes d'information de la DINUM sur lesquels il intervient.

Exigence SECU_PCA_002
Le Titulaire effectue au moins annuellement des tests de restauration des sauvegardes effectuées sur les données des systèmes d'information de la DINUM qu'il exploite en son nom.